

راهنمای کاربر مرکز فرماندهی AO-SOC

نویسنده	J.Ekrami
هم‌نویسنده	Claude (Opus 5)
حق نشر	J.Ekrami-Labs ©
تاریخ	تابستان ۱۴۰۵
نسخه سند	۱/۱
برای	ao-soc نسخه ۲/۸/۱۰

این راهنما برای **کاربران AO-SOC** نوشته شده است؛ تحلیل‌گر مرکز عملیات امنیت در شیفت، سرپرست شیفت و کسی که سامانه را نصب می‌کند. در آن می‌خوانید سامانه را چگونه نصب کنید، چگونه وارد شوید، هر منو و صفحه چه نشان می‌دهد و یک رخداد را چگونه از صف تا بایگانی پیش ببرید.

این سند راهنمای کاربردی است. برای طراحی، API ها و پیکربندی به [orchestrator/README.md](#) ، [README.md](#) و برنامه مرحله به مرحله راه اندازی در [docs/PILOT-RUNBOOK.md](#) مراجعه کنید.

همه تصاویر از محیط نمایشی (بخش ۲/۱) با رابط فارسی گرفته شده‌اند. عنوان‌ها و متن رخدادها داده‌های نمونه‌اند و از ابزارهای تشخیص به همان زبان اصلی (انگلیسی) می‌آیند؛ برچسب‌ها، دکمه‌ها و منوها فارسی‌اند.

۱. AO-SOC در یک دقیقه
۲. نصب
۳. ورود به سامانه
۴. چیدمان صفحه و نوار بالا
۵. مرکز فرماندهی (صفحه اصلی)
۶. کار روی یک رخداد: تصمیم سطح ۲ هوش مصنوعی
۷. هشدارهای زنده و راهنمای رخداد
۸. فهرست رخدادها و جزئیات رخداد
۹. بایگانی و بازگردانی اقدامها
۱۰. ریسک موجودیتها
۱۱. سلامت سامانه
۱۲. زبان: فارسی و انگلیسی
۱۳. روال روزانه
۱۴. واژه‌نامه: نشان‌ها، رنگ‌ها و وضعیت‌ها
۱۵. رفع اشکال

۱. AO-SOC در یک دقیقه

AO-SOC لایهٔ **تصمیم‌گیری** یک مرکز عملیات امنیت است. این سامانه **لاگ جمع نمی‌کند**، **لاگ ذخیره نمی‌کند** و **حمله را تشخیص نمی‌دهد**. این کارها را ابزارهای موجود شما انجام می‌دهند (Splunk، Wazuh، Elastic، Sentinel، CrowdStrike یا هر ابزاری که CEF می‌فرستد). AO-SOC با آنچه این ابزارها می‌فرستند چهار کار انجام می‌دهد:

۱. **همیشه می‌کند**. تشخیص‌های ابزارهای مختلف دربارهٔ یک کاربر، میزبان یا نشانی در یک بازهٔ زمانی، یک **وضعیت امنیتی** واحد می‌شوند. برای نمونه، یک هشدار brute-force از Splunk، یک ارتقای دسترسی از Wazuh و یک اتصال خروجی مشکوک در فایروال روی یک حساب، یک رخداد می‌شوند نه سه رخداد.
۲. **تصمیم پیشنهاد می‌کند**. یک مدل هوش مصنوعی محلی (از طریق Ollama و کاملاً درون سازمان) وضعیت را می‌خواند و یک **تصمیم سطح ۲** پیشنهاد می‌دهد: `IGNORE` یا `CONTAIN`، `ESCALATE`، `INVESTIGATE`، `MONITOR`. همراه آن یک **برنامهٔ اقدام یکپارچه** هم پیشنهاد می‌کند، مانند `Block IP`، `Isolate host` یا `Disable account`.
۳. **از انسان می‌پرسد**. شما برنامه را یک‌بار بررسی می‌کنید و **تأیید برنامه**، **ویرایش** یا **رد** را می‌زنید.
۴. **اجرا و ثبت می‌کند**. اقدام‌های تأییدشده به ابزارهای پاسخ شما (SOAR، EDR، فایروال، سامانهٔ هویت) فرستاده می‌شوند. هر گام حسابرسی می‌شود و هر اقدامی که قابل بازگردانی باشد از همین داشبورد **بازگردانی** می‌شود.

Detection tools → AO-SOC correlation → AI Tier-2 decision → YOU (approve / edit / reject)
→ policy guardrails → response tools → audit, archive, rollback

«**راهنما**» (Playbook) در AO-SOC. در این سامانه، راهنما همان **برنامهٔ اقدامی است که به هر تصمیم پیوست می‌شود**. آن را در دو جا می‌بینید: **برنامهٔ اقدام یکپارچه** در پنل تصمیم سطح ۲ هوش مصنوعی، که آن را تأیید می‌کنید و اجرا می‌شود؛ و فهرست **راهنمای رخداد** در صفحهٔ هشدارهای زنده، که فقط خلاصه‌ای از مراحل مهار را نشان می‌دهد. راهنما را دستی نمی‌نویسید. هوش مصنوعی برای هر رخداد یکی پیشنهاد می‌دهد و شما آن را تأیید، اصلاح یا رد می‌کنید.

۲. نصب

AO-SOC را به دو شکل می‌توان اجرا کرد:

بخش	کاربرد	
۲/۱	آشنایی، آموزش، ضبط ویدیو، هشدارهای نمونه، بدون نیاز به مدل واقعی	نمایشی
۲/۲	آزمایش میدانی یا استقرار واقعی با تشخیص‌های واقعی	عملیاتی (Docker)

۲/۰ پیش‌نیازها

جزء	نسخه	کاربرد
Python	۳/۱۱ یا بالاتر	کارگزار (حالت نمایشی)
npm و Node.js	۲۰ یا بالاتر	API رابط کاربری و داشبورد (حالت نمایشی)
Docker و Docker Compose	نسخه جدید	حالت عملیاتی
Ollama با مدل qwen3.5:latest (یا qwen2.5:7b)	اختیاری	تصمیم‌های واقعی هوش مصنوعی. بدون مدل، سامانه در حالت بدون مدل کار می‌کند و یک قاعده جایگزین تصمیم می‌گیرد
مرورگر	Edge، Chrome یا Firefox به‌روز	داشبورد. برای ۱۹۲۰×۱۰۸۰ و بزرگ‌تر طراحی شده؛ روی تبلت و گوشی هم کار می‌کند

درگاه‌ها (پورت‌ها)

سرویس	درگاه	توضیح
کارگزار (موتور تصمیم هوش مصنوعی)	8500	تشخیص‌ها را دریافت می‌کند
API رابط کاربری	4317	داده‌های داشبورد را می‌رساند
داشبورد (نمایشی، Vite)	5173	http://localhost:5173
داشبورد (عملیاتی، Docker)	8080	تنها درگاهی که Docker بیرون می‌دهد. با DASHBOARD_PORT قابل تغییر است

۲/۱ نصب نمایشی (ویندوز، لینوکس، macOS)

گام ۱. کد را دریافت کنید و در پوشه `ao-soc` یک ترمینال باز کنید.

گام ۲. همه چیز را با یک فرمان اجرا کنید.

ویندوز (PowerShell):

```
.\scripts\start-demo.ps1
```

لینوکس و macOS:

```
chmod +x scripts/start-demo.sh scripts/stop-demo.sh
./scripts/start-demo.sh
```

این اسکریپت:

۱. بررسی می‌کند Python و Node نصب باشند،
۲. وابستگی‌ها را نصب می‌کند (در اجراهای بعدی با `-SkipInstall` یا `--skip-install` از این گام بگذرید)،
۳. کارگزار، API رابط کاربری و داشبورد را هر کدام در یک پنجره جدا اجرا می‌کند،
۴. **۱۲ هشدار نمونه** بارگذاری می‌کند، از جمله یک وضعیت که از سه ابزار همبسته شده است،
۵. **کلید ورود کاربر را چاپ می‌کند.**

Sign in at the dashboard with this operator key:

Xy7...your-key...Qp

کلید را کپی کنید؛ در **بخش ۳** به آن نیاز دارید.

گام ۳. نشانی `http://localhost:5173` را در مرورگر باز کنید.

گونه‌های حالت نمایشی

فرمان (ویندوز / لینوکس)	نتیجه
<code>start-demo.ps1 / start-demo.sh</code>	۱۲ هشدار یک‌جا بارگذاری می‌شود
<code>start-demo.ps1 -Live / start-demo.sh --live</code>	هشدارها در حدود ۲ دقیقه یکی‌یکی می‌رسند و پرشدن صف را می‌بینید
<code>start-demo.ps1 -Ai -Count 6 / start-demo.sh --ai --count 6</code>	هوش مصنوعی واقعی: مدل محلی Ollama هر هشدار را تحلیل می‌کند. برای هر هشدار ۱۰ تا ۴۰ ثانیه زمان در نظر بگیرید

توقف حالت نمایشی:

```
.\scripts\stop-demo.ps1
```

```
./scripts/stop-demo.sh
```

هر بار که حالت نمایشی را اجرا می‌کنید، هشدارهای نمایشی **از نو ساخته می‌شوند**. اسکریپت‌های نمایشی را روی پایگاه داده عملیاتی اجرا نکنید.

۲/۲ نصب عملیاتی (Docker)

استقرار عملیاتی از برنامه مرحله به مرحله docs/PILOT-RUNBOOK.md پیروی می‌کند. به طور خلاصه:

گام ۱. فایل تنظیمات را بسازید.

```
cp deploy/.env.example deploy/.env
```

گام ۲. برای هر نفر و هر سامانه یک کلید جدا بسازید. این فرمان را برای هر کلید یکبار اجرا کنید:

```
python -c "import secrets; print(secrets.token_urlsafe(32))"
```

کلیدها را در `deploy/.env` بنویسید:

تنظیم	دارنده کلید	نمونه
<code>BROKER_API_KEYS</code>	سامانه‌ها: SIEM با نقش API ، ingest رابط کاربری با نقش service	<code>ui-api:service:<key>,siem:ingest:<key></code>
<code>UI_API_BROKER_KEY</code>	API رابط کاربری: همان رمز مدخل service بالا	<code><key></code>
<code>AOSOC_API_KEYS</code>	هر تحلیل‌گر به صورت شخصی، برای ورود به داشبورد	<code>soclead:analyst:<key>,dutydesk:viewer:<key></code>

قالب هر مدخل `name:role:secret` است و مدخل‌ها با ویرگول انگلیسی از هم جدا می‌شوند. به هر تحلیل‌گر **کلید خودش را بدهید**. تأییدها، ویرایش‌ها و بازگردانی‌ها به نام صاحب کلید ثبت می‌شوند؛ کلید مشترک ردپای می‌سازد که نام هیچ‌کس در آن نیست.

گام ۳. تنظیمات را بررسی و سپس سامانه را اجرا کنید.

```
python deploy/check_env.py
```

```
docker compose --env-file deploy/.env -f deploy/docker-compose.yml up -d
```

`check_env.py` هشدار می‌دهد اگر تغییری که در پوسته شما مانده (مثلاً از حالت نمایشی) بی‌صدا بر `deploy/.env` غلبه کند.

گام ۴. داشبورد را باز کنید: `http://<server>:8080` و با کلید تحلیل‌گر خود وارد شوید.

گام ۵. ابزارهای تشخیص را به کارگزار وصل کنید. برای نمونه، Splunk به `POST http://<broker-host>:8500/detections` می‌فرستد. هر درخواست باید کلید **ingest** را در سرآیند `X-API-Key` داشته باشد؛ تشخیصی که بدون کلید برسد پذیرفته نمی‌شود.

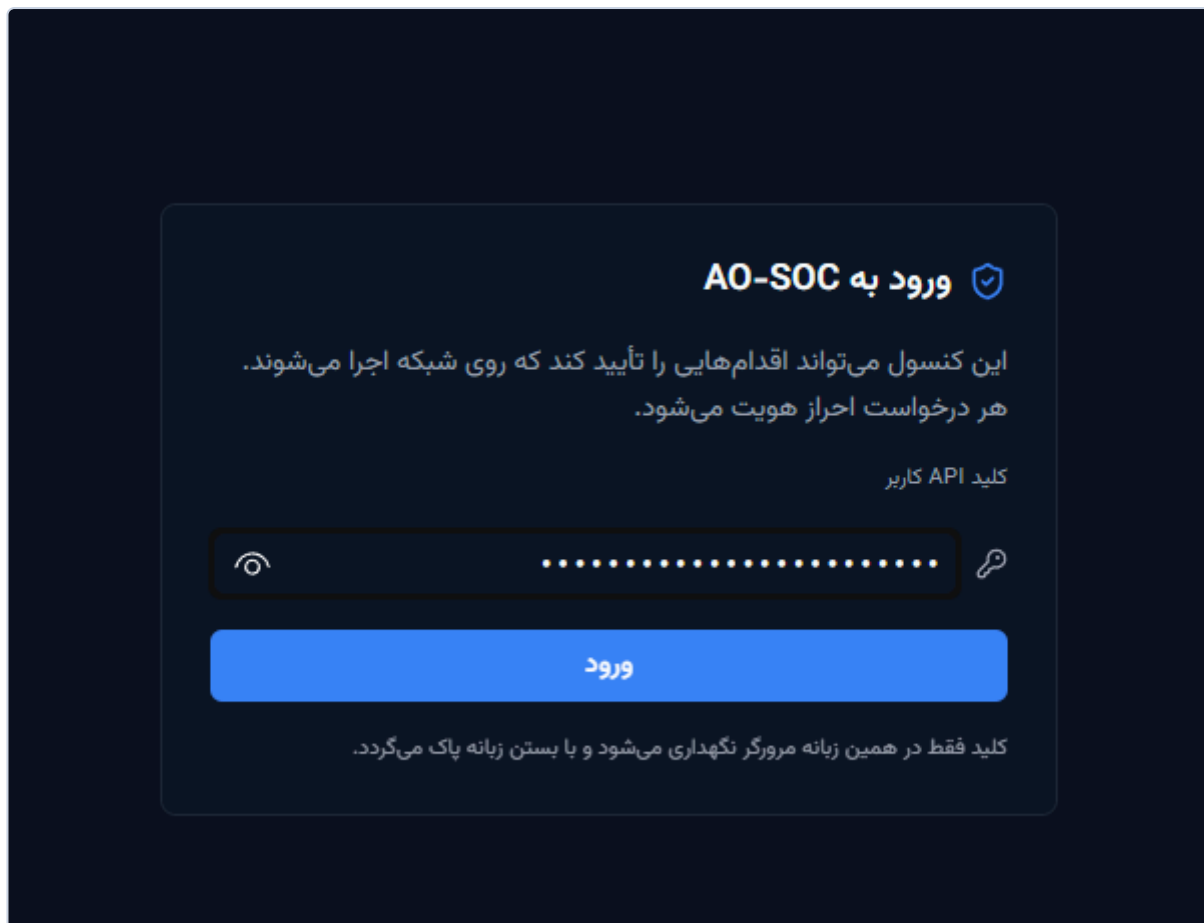
پیش‌فرض‌های امن. نصب تازه با این تنظیمات آغاز می‌شود: `LLM_PROVIDER=echo` (بدون مدل)، `TIER2_AUTOPILOT=false` (همه‌چیز را انسان تأیید می‌کند) و `RESPONSE_DRY_RUN=true` (چیزی به هیچ ابزار واقعی فرستاده نمی‌شود). این‌ها را همان‌طور که در برنامه راه‌اندازی آمده، یکی‌یکی فعال کنید.

۲٫۳ نقش‌ها

نقش	اختیار
<code>viewer</code>	دیدن همه‌چیز؛ بدون امکان تأیید، ویرایش، رد یا بازگردانی
<code>analyst</code>	دیدن و اقدام؛ تأیید، ویرایش، رد، ثبت نتیجه، بازگردانی، کار روی پرونده
<code>ingest</code>	نقش سامانه‌ای: فقط ارسال تشخیص

نقش	اختیار
service	نقش سامانه‌ای: API رابط کاربری که از طرف تحلیل‌گر وارد شده عمل می‌کند
admin	همه‌چیز. به‌طور پیش‌فرض به کسی ندهید

۳. ورود به سامانه



ورود به AO-SOC 

این کنسول می‌تواند اقدام‌هایی را تأیید کند که روی شبکه اجرا می‌شوند.
هر درخواست احراز هویت می‌شود.

کلید API کاربر

ورود

کلید فقط در همین زمانه مرورگر نگهداری می‌شود و با بستن زمانه پاک می‌گردد.

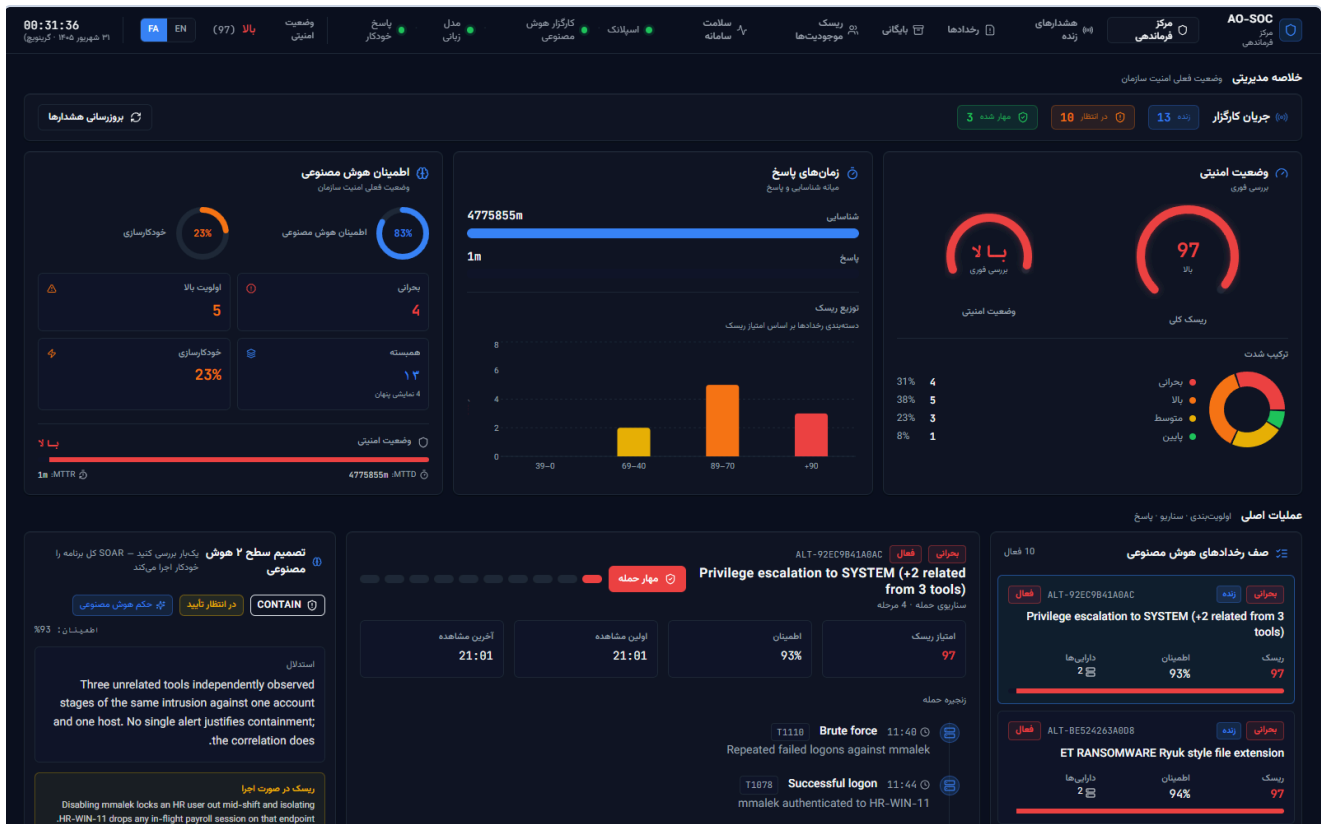
۱. نشانی داشبورد را باز کنید.

۲. **کلید API کاربر** خود را در کادر وارد کنید.

۳. روی **ورود** کلیک کنید.

کلید فقط در همین زمانه مرورگر نگهداری می‌شود. با بستن زمانه از سامانه خارج می‌شوید، پس رایانه مشترک مرکز عملیات برای شیفیت بعد وارد شده نمی‌ماند. اگر کلید نادرست یا باطل‌شده باشد، صفحه ورود دوباره نمایش داده می‌شود.

۴. چیدمان صفحه و نوار بالا



همهٔ صفحه‌ها **نوار بالای** یکسانی دارند. در رابط فارسی، نوار از راست به چپ چیده می‌شود:



شماره	بخش	کاربرد
۱	نشان AO-SOC	بازگشت به مرکز فرماندهی
۲	منوی اصلی	شش صفحهٔ سامانه (جدول زیر)
۳	وضعیت خط لوله	نقطهٔ سبز یعنی آنلاین، کهربایی یعنی تضعیف‌شده، قرمز یعنی آفلاین و خاکستری یعنی نامشخص. هر ۵ ثانیه به‌روز می‌شود
۴	وضعیت امنیتی	وضعیت کلی امنیت (پایین / محافظت‌شده / افزایش‌یافته / بالا) با امتیاز ۰ تا ۱۰۰
۵	EN / FA	تغییر زبان میان انگلیسی و فارسی
-	ساعت	ساعت و تاریخ محلی (خورشیدی در رابط فارسی)

منوی اصلی

گزینهٔ منو	صفحه	برای اینکه...
مرکز فرماندهی	/	همه‌چیز را یک‌جا ببینید و روی رخدادها کار کنید. صفحهٔ اصلی شماست
هشدارهای زنده	/alerts	گزارش خام هشدارها را مرور کنید و راهنمای مهار هر هشدار را ببینید
رخدادها	/incidents	فهرست کامل رخدادها را ببینید و هر کدام را با جزئیات باز کنید

گزینهٔ منو	صفحه	برای اینکه...
بایگانی	/archive	رخداد‌های بسته‌شده را مرور کنید: چه تصمیمی گرفته شد، چه کسی تأیید کرد، چه اجرا شد
ریسک موجودیت‌ها	/entities	پریسک‌ترین کاربران، میزبان‌ها و نشانی‌های IP را ببینید
سلامت سامانه	/health	زنده بودن خط لوله و داده‌های پایش آن را بررسی کنید

پانویس صفحه نسخهٔ برنامه (مثلاً v2.8.9) و مسیر خط لوله را نشان می‌دهد. هنگام گزارش اشکال، نسخه را ذکر کنید.

۵. مرکز فرماندهی (صفحه اصلی)

مرکز فرماندهی از بالا به پایین به پنج پرسش پاسخ می‌دهد: اکنون چه چیزی نیاز به توجه دارد؟ چقدر جدی است؟ چرا هوش مصنوعی چنین فکر می‌کند؟ چه باید کرد؟ وضعیت امنیتی ما چیست؟ این صفحه شش ردیف دارد.

۵/۱ خلاصه مدیریتی: «الان وضع چطور است؟»

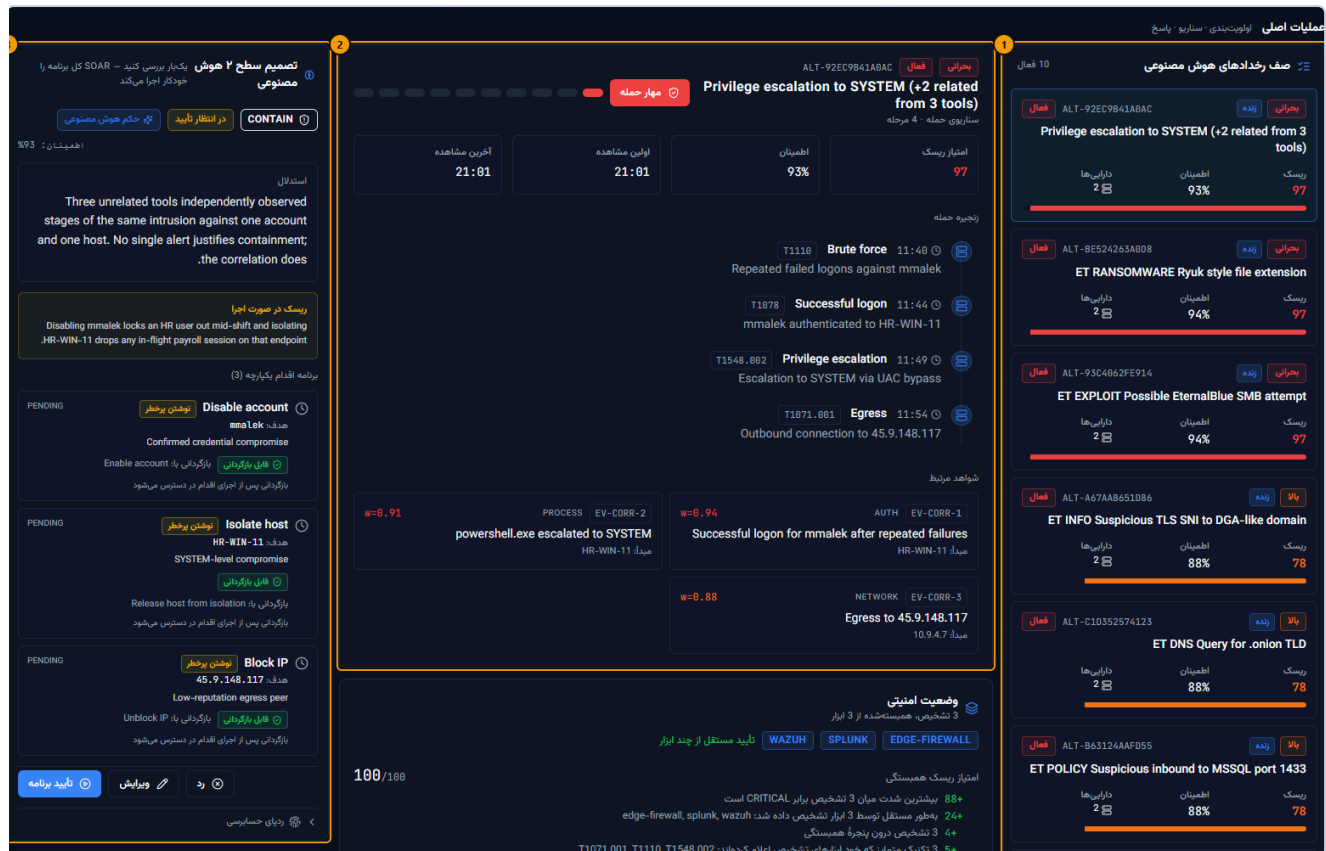


- **جریان کارگزار.** شمار رخدادهای زنده، رخدادهای در انتظار تصمیم انسانی و رخدادهای مهار شده. دکمه بروزرسانی هشدارها بی‌درنگ آن‌ها را از نو بارگذاری می‌کند؛ صفحه هر ۱۵ ثانیه خودش هم به‌روز می‌شود.
- **وضعیت امنیتی.** شاخص ریسک کلی (۰ تا ۱۰۰) با برجسب آن و نمودار دایره‌ای ترکیب شدت رخدادهای باز.
- **زمان‌های پاسخ.** MTTR (میانگین زمان شناسایی) و MTTR (میانگین زمان پاسخ)، به‌همراه نمودار توزیع ریسک رخدادها بر اساس امتیاز.
- **اطمینان هوش مصنوعی.** میانگین اطمینان مدل، نرخ خودکارسازی و شمار رخدادهای بحرانی، اولویت بالا و همیشه.

اطمینان هوش مصنوعی نمایش داده می‌شود، اما هرگز مبنای تصمیم نیست. مدل‌های محلی تقریباً برای هر ورودی ۷۵ تا ۹۸ درصد اطمینان گزارش می‌کنند. از این عدد برای مرتب‌کردن کارها استفاده کنید، نه به‌عنوان دلیل تأیید.

۵/۲ عملیات اصلی: اولویت‌بندی، سناریو و پاسخ

کار روی رخدادها در این بخش انجام می‌شود.



شماره	پنل	آنچه نشان می‌دهد
۱	صف رخدادهای هوش مصنوعی (سمت راست)	رخدادهای فعال، فوری‌ترین در بالا، روی یکی کلیک کنید تا انتخاب شود؛ همه پنل‌های کناری سپس همان رخداد را نشان می‌دهند
۲	سناریوی حمله و پنل‌های زیر آن (وسط)	چه اتفاقی افتاد، به ترتیب زمانی، و شواهد پشت آن
۳	تصمیم سطح ۲ هوش مصنوعی و اقدامات پیشنهادی هوش مصنوعی (سمت چپ)	آنچه هوش مصنوعی پیشنهاد می‌دهد و دکمه‌هایی که با آن‌ها اقدام می‌کنید (بخش ۶)

صف رخدادهای هوش مصنوعی

صف رخدادهای هوش مصنوعی

فعال 10

فعال

ALT-92ED9B41A8AC

زنده

بحرانی

Privilege escalation to SYSTEM (+2 related from 3 tools)

دارایی‌ها

اطمینان

ریسک

2

93%

97

فعال

ALT-BE524263A6D8

زنده

بحرانی

ET RANSOMWARE Ryuk style file extension

دارایی‌ها

اطمینان

ریسک

2

94%

97

فعال

ALT-93C4B62FE914

زنده

بحرانی

ET EXPLOIT Possible EternalBlue SMB attempt

دارایی‌ها

اطمینان

ریسک

2

94%

97

فعال

ALT-A67AAB651D86

زنده

بالا

ET INFO Suspicious TLS SNI to DGA-like domain

دارایی‌ها

اطمینان

ریسک

2

88%

78

فعال

ALT-C1D352574123

زنده

بالا

ET DNS Query for .onion TLD

دارایی‌ها

اطمینان

ریسک

2

88%

78

فعال

ALT-B63124AAF055

زنده

بالا

ET POLICY Suspicious inbound to MSSQL port 1433

دارایی‌ها

اطمینان

ریسک

2

88%

78

فعال

ALT-FC7173C7367B

زنده

بالا

ET POLICY Powershell DownloadString

دارایی‌ها

اطمینان

ریسک

2

88%

78

فعال

ALT-1AC3F597489B

زنده

بالا

ET MALWARE Known C2 Beacon

دارایی‌ها

اطمینان

ریسک

2

88%

78

فعال

ALT-3928D957346C

زنده

متوسط

ET WEB_SERVER SQL Injection Attempt

دارایی‌ها

اطمینان

ریسک

2

71%

62

فعال

ALT-BC126E54C699

زنده

متوسط

ET SCAN Potential SSH Scan

دارایی‌ها

اطمینان

ریسک

2

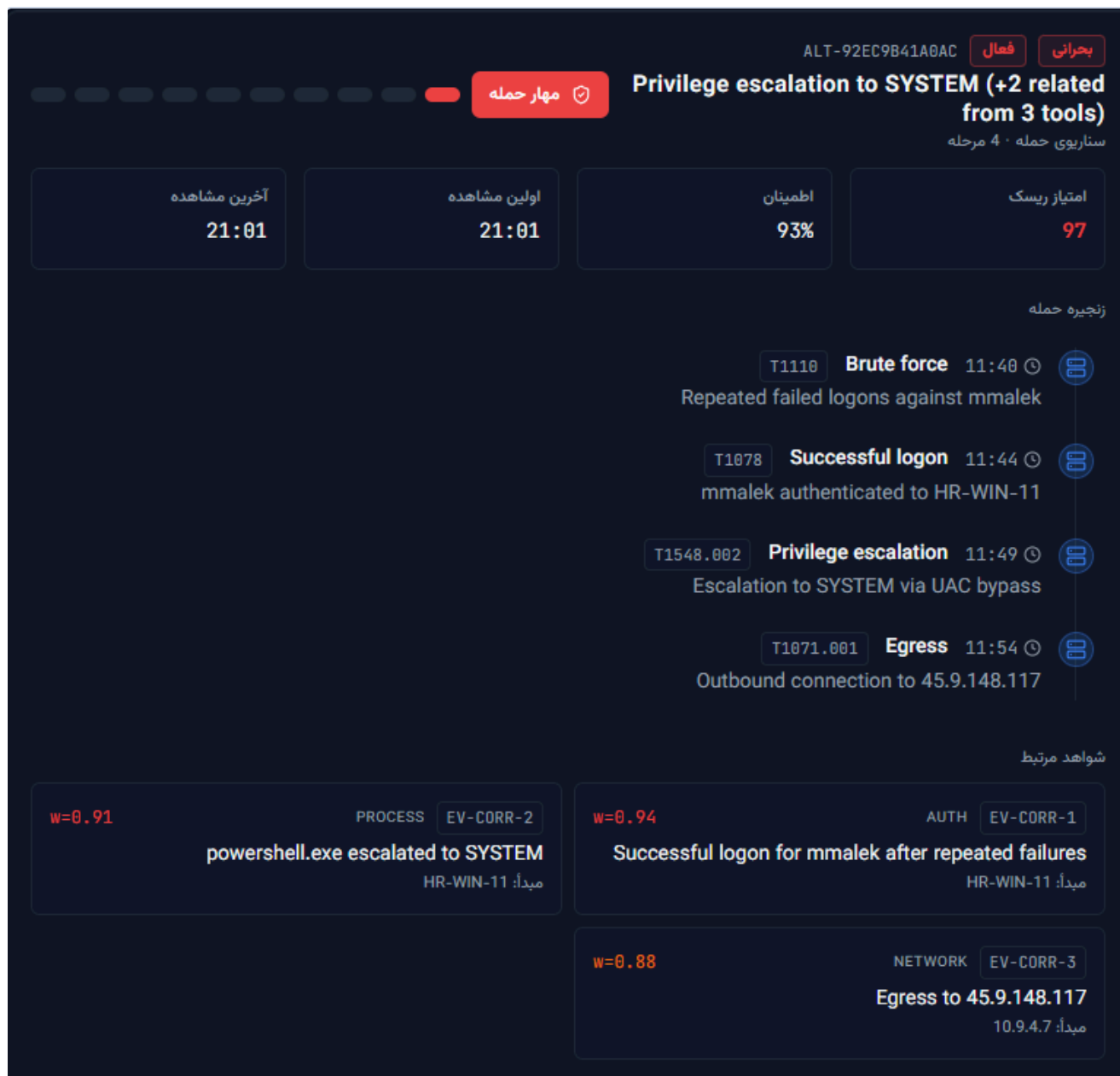
71%

62

هر کارت نشان می‌دهد: **شدت** (بحرانی، بالا، متوسط، پایین)، نشان **زنده** (داده واقعی کارگزار؛ نشان **نمایشی** یعنی داده نمونه)، شناسه رخداد، **وضعیت**، عنوان، امتیاز **ریسک**، **اطمینان** هوش مصنوعی و شمار **دارایی‌های** درگیر. نوار پایین کارت همان امتیاز ریسک است که با رنگ شدت نمایش داده می‌شود.

عنوانی مانند «*Privilege escalation to SYSTEM (+2 related from 3 tools)*» یعنی AO-SOC سه تشخیص از سه ابزار متفاوت را در یک وضعیت واحد به هم پیوند داده است.

سناریوی حمله



- ردیف بالا: امتیاز ریسک، اطمینان، اولین مشاهده و آخرین مشاهده.
- **زنجیره حمله.** هر مرحله حمله به ترتیب زمانی، با شناسه تکنیک MITRE ATT&CK (مثلاً T1110 برای Brute force).
- **شواهد مرتبط.** تک تک شواهد، نوع آنها (احراز هویت، فرایند، شبکه) و وزنشان.
- **مهار حمله** (دکمه قرمز). رخداد را دستی **مهار شده** علامت می‌زند، بدون اجرای برنامه. فقط وقتی از آن استفاده کنید که تهدید بیرون از AO-SOC مهار شده باشد. راه عادی، **تأیید برنامه** است (بخش ۶).

وضعیت امنیتی: چرا چند هشدار یک رخداد شدند

وضعیت امنیتی

3 تشخیص، همبسته شده از 3 ابزار

WAZUH

SPLUNK

EDGE-FIREWALL

تأیید مستقل از چند ابزار

100/100

امتیاز ریسک همبستگی

88+ بیشترین شدت میان 3 تشخیص برابر CRITICAL است

24+ به طور مستقل توسط 3 ابزار تشخیص داده شد: edge-firewall, splunk, wazuh

4+ 3 تشخیص درون پنجره همبستگی

5+ 3 تکنیک متمایز که خود ابزارهای تشخیص اعلام کرده اند: T1071.001, T1110, T1548.002

همبسته بر اساس

powershell.exe

HR-WIN-11

45.9.148.117

10.9.4.7

203.0.113.44

mmalek

تشخیص های عضو

07:10 متوسط SPLUNK >

Brute force against a single account

07:19 بحرانی WAZUH >

Privilege escalation to SYSTEM

07:24 بالا EDGE-FIREWALL >

Outbound connection to a low-reputation host

توجه: در رابط فارسی، عنوان این پنل و برچسب «وضعیت امنیتی» در نوار بالا یکسان است. پنل درباره تشخیص های همبسته است و برچسب نوار بالا درباره وضعیت کلی امنیت سازمان.

- نشان های ابزار (مثلاً WAZUH ، SPLUNK ، EDGE-FIREWALL) ابزارهایی را نام می برند که آن را گزارش کرده اند. تأیید مستقل از چند ابزار یعنی بیش از یک ابزار آن را دیده است.
- امتیاز ریسک همبستگی. محاسبه را سطر به سطر نشان می دهد: امتیاز بیشترین شدت، همبستگی میان ابزارها، شمار تشخیص ها و شمار تکنیک ها. این امتیاز شمارشی از واقعیت هاست، نه نظر هوش مصنوعی.
- همبسته بر اساس. کاربران، نشانی ها، میزبان ها و فرایندهای مشترکی که تشخیص ها را به هم پیوند داده اند.
- تشخیص های عضو. همه تشخیص های اصلی. روی < کلیک کنید تا یکی باز شود و موجودیت ها، تکنیک ها و پیوند بازگشت به ابزار مبدأ آن را ببینید.

راستی آزمایی و سابقه

راستی آزمایی و سابقه

چه چیزی در برابر یک مرجع بررسی شد و این مرکز عملیات پیش تر چه تصمیمی گرفته است

sample-data egress credential-theft sample-indicator-set 45.9.148.117 MALICIOUS

2 مورد بررسی نشد (نشانی های داخلی و هویت ها هرگز به فید فرستاده نمی شوند)

سابقه

سابقه به اندازه مشابهی وجود ندارد — این تصمیم به اقتضای طراحی منتظر تحلیل گر می ماند.

- **نشانه‌هایی که در برابر هوش تهدید بررسی شدند.** نشان MALICIOUS یعنی نشانه در یک فید آمده است. «بررسی شد و یافت نشد» دلیل بی‌خطر بودن نیست. «بررسی نشد» شامل نشانه‌های داخلی و هویت‌هاست که هرگز به فید فرستاده نمی‌شوند.
- **سابقه.** تصمیم‌های پیشین همین مرکز عملیات در موارد مشابه. پیام «سابقه به‌اندازه مشابهی وجود ندارد» یعنی این رخداد به‌اقتضای طراحی منتظر تحلیل‌گر می‌ماند.

پنل خالی به معنای نتیجه پاک نیست. اگر هیچ فید هوش تهدیدی پیکربندی نشده باشد، پنل همین را صریح می‌گوید.

پرونده: چه کسی مسئول این رخداد است

پرونده
چه کسی روی آن کار می‌کند و در چه وضعیتی است

P1 تازه

CASE-FCBC4A8B46

هنوز کسی مسئول این پرونده نیست

بازگرداندن به صف

واگذاری به...

ارجاع به سطح بالاتر

بسته‌شده

حل‌شده

ارجاع‌شده

در دست بررسی

واگذارشده

افزودن یادداشت

افزودن یادداشت به پرونده...

سامانه مرجع

هیچ سامانه تیکتینگ پیکربندی نشده است. این پرونده تنها همین‌جا نگهداری می‌شود – ناهماهنگ نیست، چیزی برای هماهنگ‌شدن وجود ندارد.

سوابق پرونده

پرونده برای موقعیت SIT-9D042D292ED1 گشوده شد - 9/21/2026, 9:01:18 PM - ao-soc

- **شناسه پرونده، وضعیت و اولویت آن (P1 بالاترین اولویت است).**
- **واگذاری به...** نامی بنویسید و **واگذاری** را بزنید. **بازگرداندن به صف** مسئول پرونده را برمی‌دارد.
- **دکمه‌های وضعیت** پرونده را در چرخه عمرش پیش می‌برند: تازه ← واگذارشده ← در دست بررسی ← ارجاع‌شده ← حل‌شده ← بسته‌شده، و از حل‌شده یا بسته‌شده به بازگشایی‌شده. فقط وضعیت‌های مجاز بعدی نمایش داده می‌شوند.
- **ارجاع به سطح بالاتر** پرونده را به سطح بعدی می‌فرستد.
- **افزودن یادداشت** در **سوابق پرونده** می‌نویسد؛ سوابق پرونده بعداً قابل ویرایش نیست.
- **سامانه مرجع.** نشان می‌دهد پرونده با سامانه تیکتینگ (مثلاً TheHive) همگام است یا نه. پیام «هیچ سامانه تیکتینگ پیکربندی نشده است» یک وضعیت عادی است، نه خطا.

هیچ‌چیز در پنل پرونده نمی‌تواند تصمیمی را تأیید یا رد کند. مسئولیت پرونده و تصمیم درباره آن عمده‌اً از هم جدا نگه داشته شده‌اند.

اقدامات پیشنهادی هوش مصنوعی

3 اقدام
اقدامات پیشنهادی هوش مصنوعی

A1

Disable account

هدف: mmalek

Confirmed credential compromise

Locks the user out

94%

دلیل

اثر

اطمینان

برنامه سطح ۲ بالا را تأیید کنید تا اجرای خودکار انجام شود

A2

Isolate host

هدف: HR-WIN-11

SYSTEM-level compromise

Contains the endpoint

92%

دلیل

اثر

اطمینان

برنامه سطح ۲ بالا را تأیید کنید تا اجرای خودکار انجام شود

A3

Block IP

هدف: 45.9.148.117

Low-reputation egress peer

Stops egress

98%

دلیل

اثر

اطمینان

برنامه سطح ۲ بالا را تأیید کنید تا اجرای خودکار انجام شود

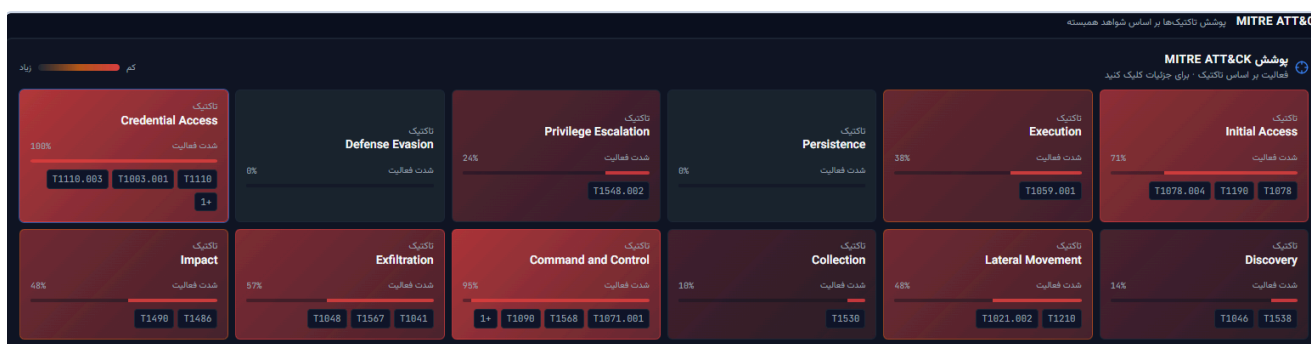
همان اقدامهای برنامه، هر کدام با **هدف**، **دلیل**، **اثر** و **اطمینان**. برای رخدادهای زنده اینها را یکی یکی اجرا نمی کنید. پیام «برنامه سطح ۲ بالا را تأیید کنید تا اجرای خودکار انجام شود» یعنی از **تأیید برنامه** استفاده کنید.

۵٫۳ تحلیل ریسک



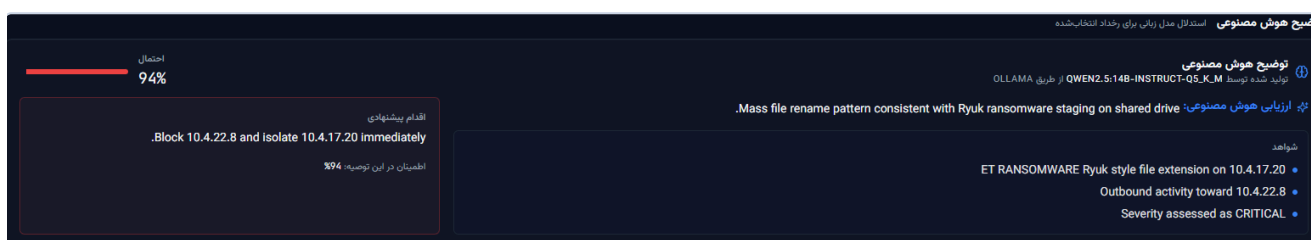
پریسک‌ترین کاربران، میزبان‌ها و نشانی‌های IP که بر وضعیت امنیتی کنونی اثر دارند. فهرست کامل و قابل جست‌وجو در صفحهٔ ریسک موجودیت‌ها است (بخش ۱۰).

MITRE ATT&CK ۵٫۴



فعالیت بر اساس تاکتیک ATT&CK. خانه‌های قرمزتر یعنی شدت فعالیت بیشتر. هر خانه شناسهٔ تکنیک‌های دیده‌شده را فهرست می‌کند؛ برای جزئیات روی خانه کلیک کنید. تکنیک‌ها با یک فهرست محلی MITRE ATT&CK سنجیده می‌شوند و شناسه‌ای که در فهرست نیست «فهرست‌نشده» علامت می‌خورد و به‌عنوان واقعیت نمایش داده نمی‌شود.

۵٫۵ توضیح هوش مصنوعی



استدلال مدل محلی برای رخداد انتخاب‌شده: ارزیابی، شواهدی که بر آن تکیه کرده، اقدام پیشنهادی و احتمال. پنل نام مدلی را هم که آن را نوشته نشان می‌دهد (مثلاً qwen2.5:14b-instruct از طریق Ollama).

۵٫۶ سلامت سامانه (پنل)



نسخه فشرده صفحه سلامت سامانه (بخش ۱۱).

۶. کار روی یک رخداد: تصمیم سطح ۲ هوش مصنوعی

این پنل قلب AO-SOC است. شما یک بار بررسی می‌کنید و ابزارهای پاسخ سپس کل برنامه را اجرا می‌کنند.

تصمیم سطح ۲ هوش مصنوعی

یک بار بررسی کنید - SOAR کل برنامه را خودکار اجرا می‌کند

CONTAIN ⓘ

در انتظار تأیید

نم: حکم هوش مصنوعی

اطمینان: 93%

استدلال

Three unrelated tools independently observed stages of the same intrusion against one account and one host. No single alert justifies containment; the correlation does

ریسک در صورت اجرا

Disabling mmalek locks an HR user out mid-shift and isolating .HR-WIN-11 drops any in-flight payroll session on that endpoint

برنامه اقدام یکپارچه (3)

PENDING

نوشتن پرخطر

Disable account ⓘ

هدف: mmalek

Confirmed credential compromise

بازگردانی با: Enable account

بازگردانی پس از اجرای اقدام در دسترس می‌شود

PENDING

نوشتن پرخطر

Isolate host ⓘ

هدف: HR-WIN-11

SYSTEM-level compromise

بازگردانی با: Release host from isolation

بازگردانی پس از اجرای اقدام در دسترس می‌شود

PENDING

نوشتن پرخطر

Block IP ⓘ

هدف: 45.9.148.117

Low-reputation egress peer

بازگردانی با: Unblock IP

بازگردانی پس از اجرای اقدام در دسترس می‌شود

رد ⓘ

ویرایش

تایید برنامه

رد پای حساب

خواندن پنل از بالا به پایین

• **حکم:** CONTAIN (مهار)، ESCALATE (ارجاع)، INVESTIGATE (بررسی)، MONITOR (پایش) یا IGNORE (نادیده گرفتن).

• **وضعیت:** در انتظار تأیید ← تأیید شده ← در حال اجرا ← تکمیل. وضعیت‌های ممکن دیگر: رد شده، ناموفق، اجرای آزمایشی، جایگزین شده.

• **چه کسی تصمیم گرفت:**

- **حکم هوش مصنوعی:** تصمیم را مدل داده است.
- **بازگشت به قاعده:** مدل پاسخ قابل استفاده‌ای نداد و یک قاعده مبتنی بر شدت تصمیم گرفت. این موارد را با دقت بیشتری بخوانید.
- **اصلاح تحلیل‌گر:** یک انسان آن را ویرایش کرده است.

• **استدلال:** دلیل تصمیم، به زبان ساده.

• **ریسک در صورت اجرا (کادر کهریایی):** اجرای برنامه چه چیزی را ممکن است مختل کند؛ مثلاً غیرفعال شدن حساب یک کاربر منابع انسانی در میانه شیف.

• **(۴) برنامه اقدام یکپارچه:** هر اقدام با:

- **هدف آن** (نشانی IP، میزبان یا حساب) و دلیل،
- **رده خطر:** فقط خواندن، نوشتن کم‌خطر، نوشتن پرخطر یا مخرب،
- **بازگشت‌پذیری:** قابل بازگردانی (با نام اقدام بازگرداننده)، بازگشت‌ناپذیر یا چیزی برای بازگرداندن نیست،

◦ نشان محافظ در صورت لزوم: **دارایی حیاتی، حساب دارای دسترسی ویژه یا حساب سرویس.** خلبان خودکار هرگز این‌ها را اجرا نمی‌کند؛ باید یک انسان تأیید کند.

• **دکمه‌ها:** (۱) تأیید برنامه، (۲) رد، (۳) ویرایش.

• **(۵) رد پای حسابرسی:** تصمیم چگونه ساخته شد (بخش ۶/۴).

۶/۱ تأیید برنامه

۱. **استدلال، پنل وضعیت امنیتی و کادر ریسک در صورت اجرا** را بخوانید.

۲. **هدف** هر اقدام را بررسی کنید: آیا میزبان، حساب یا نشانی درست است؟

۳. روی **تأیید برنامه** کلیک کنید.

همه اقدام‌ها در صف قرار می‌گیرند و خودکار اجرا می‌شوند. وضعیت هر اقدام از PENDING به EXECUTING و سپس

DONE تغییر می‌کند. وقتی همه موفق شوند، رخداد **بسته می‌شود:** از صف خارج می‌شود، به **بایگانی** می‌رود و

یک نوار سبز آن را اعلام می‌کند.

The screenshot shows the AO-SOC interface with a dark theme. At the top, there's a header with 'اصلی' (Main) and 'اولویت‌بندی: ساریو' (Priority: Sario). Below the header, a green bar indicates 'Privilege escalation to SYSTEM (+2 related from 3 tools)'. The main content area is divided into several sections. On the left, there's a sidebar with 'مشاهده بایگانی' (View Archive) and 'تصمیم سطح ۲ هوش مصنوعی' (AI Level 2 Decision). The central part shows a detailed view of an alert titled 'ET RANSOMWARE Ryuk style file extension' with a risk score of 97 and a confidence of 94%. It includes a timeline of events, a detailed description of the attack, and a 'Mass file rename pattern consistent with Ryuk ransomware staging on shared drive. Tier-2 verdict. ESCALATE for 10.4.17.20 -> 10.4.22.8'.

روی **مشاهده بایگانی** کلیک کنید تا آن را ببینید، یا با X نوار را ببندید.

اجرای آزمایشی. وقتی استقرار با `RESPONSE_DRY_RUN=true` اجرا می‌شود، اقدام‌ها به‌جای «تکمیل» وضعیت **اجرای آزمایشی** (کهریایی) می‌گیرند: «چیزی به هیچ مجری ارسال نشد». رخداد **مهار شده** علامت نمی‌خورد. این عمدی است؛ مهار شبیه‌سازی‌شده هرگز نباید شبیه مهار واقعی دیده شود.

۶/۲ ویرایش برنامه (اصلاح هوش مصنوعی)

وقتی هوش مصنوعی تا حدی درست گفته از **ویرایش** استفاده کنید: حکم اشتباه است، هدفی اشتباه است، یا اقدامی کم یا زیاد است.



۱. روی **ویرایش** کلیک کنید.

۲. در صورت نیاز **حکم** را تغییر دهید.

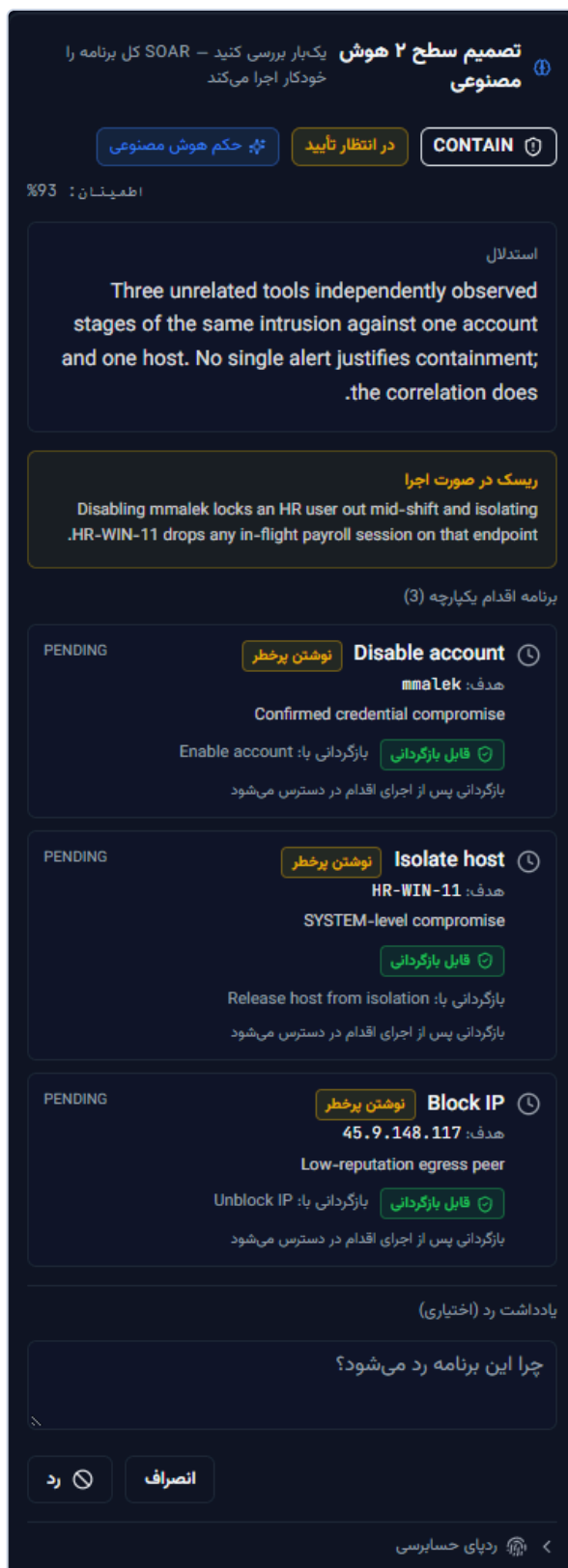
۳. نام، هدف یا دلیل هر اقدام را تغییر دهید. **افزودن اقدام** یک سطر اضافه می‌کند و نماد سطل زباله یک سطر را حذف می‌کند.

۴. در صورت تمایل بنویسید **ماشین چه چیزی را اشتباه دید؛ مثلاً «مجاز تغییر تأییدشده را ندید»**.

۵. روی **ذخیره اصلاح** کلیک کنید و سپس برنامه اصلاح‌شده را تأیید کنید.

اصلاح شما به عنوان **برچسبی** ذخیره می شود که سامانه از آن می آموزد و به *سابقه ای* تبدیل می شود که تصمیم های بعدی با آن سنجیده می شوند. ویرایش راه بهتر شدن سامانه است؛ پس یک ویرایش از یک رد بی توضیح مفیدتر است.

AO-SOC ویرایشی را که هرگز قابل اجرا نباشد نمی پذیرد؛ مثلاً اقدام *Block IP* با هدفی که نشانی IP نیست. برنامه ای که اجرا شده دیگر ویرایش پذیر نیست، چون سند آن چیزی است که فرستاده شد.



۱. روی **رد** کلیک کنید.
۲. در صورت تمایل **دلیل** را در یادداشت رد بنویسید.
۳. با زدن دوباره **رد** تأیید کنید.

چیزی اجرا نمی‌شود. وقتی هیچ اقدامی لازم نیست از رد استفاده کنید؛ مثلاً برای یک اسکنر مجاز یا یک مثبت کاذب شناخته‌شده.

۶٫۴ ردپای حسابرسی

تصمیم سطح ۲ هوش مصنوعی

یک‌بار بررسی کنید – SOAR کل برنامه را خودکار اجرا می‌کند

تپ: حکم هوش مصنوعی

در انتظار تأیید

CONTAIN

اطمینان: 93%

استدلال

Three unrelated tools independently observed stages of the same intrusion against one account and one host. No single alert justifies containment; the correlation does.

ریسک در صورت اجرا

Disabling mmalek locks an HR user out mid-shift and isolating .HR-WIN-11 drops any in-flight payroll session on that endpoint

برنامه اقدام یکپارچه (3)

PENDING

نوشتن پرخطر

Disable account

هدف: mmalek

Confirmed credential compromise

بازگردانی با: Enable account

بازگردانی پس از اجرای اقدام در دسترس می‌شود

PENDING

نوشتن پرخطر

Isolate host

هدف: HR-WIN-11

SYSTEM-level compromise

بازگردانی با: Release host from isolation

بازگردانی پس از اجرای اقدام در دسترس می‌شود

PENDING

نوشتن پرخطر

Block IP

هدف: 45.9.148.117

Low-reputation egress peer

بازگردانی با: Unblock IP

بازگردانی پس از اجرای اقدام در دسترس می‌شود

تأیید برنامه

ویرایش

رد

ردپای حسابرسی

خودگردانی

پیشنهادی – هنوز کسی تأیید نکرده

مدل

scripted · scripted

اجرا

RUN-74F8C6D0AD5B

درهم استدلال

5a00aa68f264...5e82e3ca

درستی

تأییدشده

اطمینان، گزارش خود مدل است و کالبیره نیست – نمایش داده می‌شود و هرگز برای تصمیم‌گیری به کار نمی‌رود.

دریافت JSON

روی ردپای حسابرسی کلیک کنید تا باز شود. این بخش نشان می‌دهد:

- **خودگردانی:** پیشنهادی (هنوز کسی تأیید نکرده)، زیر نظارت (یک انسان تأیید کرده) یا خودکار (خلبان خودکار بر پایه سابقه تأیید کرده).
- **مدل و اجرا:** کدام مدل تصمیم را ساخت و شناسه آن اجرا.
- **درهم استدلال** (با دکمه رونوشت) و **درستی:** «تأییدشده» یعنی پرسش و پاسخ ذخیره شده هنوز با درهم خود می خوانند؛ «ناهمخوان» یعنی رکورد دستکاری شده است.
- **دریافت JSON:** پرونده کامل تصمیم (وضعیت، تصمیم، اقدامها و ردپای حسابرسی) برای گزارش یا مستندسازی شواهد.

۶/۵ ثبت آنچه در عمل رخ داد

پس از قطعی شدن تصمیم، پنل می پرسد **در عمل چه شد** و تا ۷۲ ساعت (قابل تنظیم) می توانید پاسخ دهید:

- **مثبت درست:** حمله واقعی بود.
- **مثبت کاذب:** حمله نبود.
- **بازگشایی شده:** دوباره تکرار شد.

لطفاً نتیجه را ثبت کنید. همین پاسخ ها تعیین می کنند کدام منابع تشخیص و کدام حکمها آن قدر قابل اعتمادند که روزی خودکار شوند.

۶/۶ خلبان خودکار (در صورت فعال بودن)

اگر خلبان خودکار در سازمان فعال شده باشد، برخی تصمیمها **بدون** کلیک اجرا می شوند. این کار فقط زمانی انجام می شود که به اندازه کافی موارد مشابه پیشین با همان حکم توسط انسان تأیید شده باشند، هیچ کدام برگردانده نشده باشد و جدیدترینشان تازه باشد. خلبان خودکار هرگز اینها را خودکار انجام نمی دهد:

- اقدام روی دارایی حیاتی (کنترل کننده های دامنه، پایگاه های داده و هر آنچه سازمان فهرست کرده)،
- غیرفعال کردن یا بازنشانی حساب دارای دسترسی ویژه یا حساب سرویس،
- اقدامی که بازگشت ناپذیر است،
- اقدام مخرب.

در بایگانی، رخدادهایی که خلبان خودکار بسته، به جای نشان تحلیل گر نشان خلبان خودکار دارند.

۷. هشدارهای زنده و راهنمای رخداد

منو: هشدارهای زنده. گزارش خام هشدارهای کارگزار، برای مرور سریع.

08:32:07
۱۳ شهریور ۱۴۰۵ - کربلا

FA EN

بالا (97) وضعیت امنیتی

راسخ خودکار مدلی زانی مصنوعی کارگزار هوش اسبابک مصنوعی سلامت سامانه پارس موجدیت‌ها ریسک

آلودگی‌ها

هشدارهای تازه

مرکز فرماندهی

AO-SOC

گزارش هشدارهای تازه
هشدارهای دریافتی از اسپایک توسط کارگر آرگوس-Angels-Link

بازبینی

میانگین / پایین	بالا	بحران	مهار شده	در انتظار	هشدارهای زنده
2	5	2	4	9	13

مهار حمله

راهنامه‌ی رخداد
 ALT-BES2426SAOD8
 تحلیل هوش مصنوعی

Mass file rename pattern consistent with Ryuk ransomware staging on shared drive.

توصیه اصلی

- Block egress to 10.4.22.8 at the perimeter firewall
 🔘
- Isolate host 10.4.17.20 from the network segment
 🔘
- Collect memory dump and triage for credential theft
 🔘

توصیه اصلی

.Block 10.4.22.8 and isolate 10.4.17.20 immediately

9 هشدار کارگر

زمان	شدت	وضعیت	مبدأ	مقصد	انصاف
21:01	بحرانی	فعال	10.4.17.20	10.4.22.8	_Ryuk style file extension
21:01	بحرانی	فعال	10.4.9.17	10.4.21.58	_ternalBlue SMB attempt
21:01	بالا	فعال	10.4.73.16	198.51.108.14	_SNI to DGA-like domain
21:01	بالا	فعال	10.4.59.14	8.8.8.8	_NS Query for .onion TLD
21:01	بالا	فعال	10.4.98.12	193.142.146.4	_nd to MSSQL port 1433
21:01	بالا	فعال	10.4.183.18	283.8.113.44	_ershell DownloadString
21:01	بالا	فعال	10.4.21.18	185.228.181.7	_ARE Known C2 Beacon
21:01	متوسط	فعال	10.4.38.15	177.185.83.48	_R SQL Injection Attempt
21:01	متوسط	فعال	10.4.45.11	45.155.285.211	_AN Potential SSH Scan

اسپیکت - کارگذار فوق مصنوعی - مدل مبتنی (Qwen) - پاسخ خودکار
مرکز فرماندهی AO-SOC - v2.8.8

- **کاشی‌های بالا:** شمار هشدارهای زنده، در انتظار، مهار شده، بحرانی، بالا و متوسط / پایین.
- **گزارش هشدار:** زمان، شدت، وضعیت، نشانی مبدأ و مقصد و امضا. **بروزرسانی** گزارش را از نو بارگذاری می‌کند.

روی یک هشدار کلیک کنید تا راهنمای رخدادهای آن در کنار صفحه باز شود:

88:32:09

۳۱ شهریور ۱۴۰۵ - گریبویچ

FA EN

97

ایلا

وضعیت امنیتی

پاسخ خودکار

مدل زبانی

کارگزار هوش مصنوعی

اسپلنک

سلامت سامانه

ریسک موجودیت‌ها

پایگانی

رخداده‌ها

هشدارهای زنده

مرکز فرماندهی

AO-SOC

مرکز فرماندهی

گزارش هشدارهای زنده

Aegis-Link توسط کارگزار Aegis-Link

هشدارهای زنده

13

در انتظار

9

مهار شده

4

بحرانی

2

ایلا

5

متوسط / پایین

2

بروزرسانی

راهنمای رخداد

ALT-93C4062FE914

تحلیل هوش مصنوعی

SMB exploit traffic targeting file server – Immediate lateral movement risk

مهار پیشنهادی

توصیه اصلی

Block 10.4.21.50 and isolate 10.4.9.17 immediately

Collect memory dump and triage for credential theft

Isolate host 10.4.9.17 from the network segment

Block egress to 10.4.21.50 at the perimeter firewall

9 هشدار کارگزار

زمان	شدت	وضعیت	مبدأ	مقصد	انبار
21:01	بحرانی	فعال	10.4.17.20	10.4.22.8	...Ryuk style file extension
21:01	بحرانی	فعال	10.4.9.17	10.4.21.50	...ternalBlue SMB attempt
21:01	ایلا	فعال	10.4.73.16	198.51.100.14	...SNI to DGA-like domain
21:01	ایلا	فعال	10.4.59.14	8.8.8.8	...NS Query for .onion TLD
21:01	ایلا	فعال	10.4.90.12	193.142.146.4	...nd to MSSQL port 1433
21:01	ایلا	فعال	10.4.103.18	203.0.113.44	...erashell DownloadString
21:01	ایلا	فعال	10.4.21.10	185.220.101.7	...ARE Known C2 Beacon
21:01	متوسط	فعال	10.4.30.15	177.185.83.40	...R SQL Injection Attempt
21:01	متوسط	فعال	10.4.45.11	45.155.205.211	...AN Potential SSH Scan

مرکز فرماندهی v2.8.8 - AO-SOC

اسپلنک - کارگزار هوش مصنوعی - مدل محلی (Qwen) - پاسخ خودکار

- **تحلیل هوش مصنوعی:** خلاصه‌ای یک‌خطی.
 - **مهار پیشنهادی:** مراحل راهنما به شکل فهرست بررسی. هر مرحله پس از انجام، سبز و تیک‌خورده می‌شود.
 - **توصیه اصلی:** مهم‌ترین گام.
 - **مهار حمله:** هشدار را دستی مهار شده علامت می‌زند (بخش ۵/۲ را ببینید).
- برای **تأیید و اجرای** راهنما، رخداد را در **مرکز فرماندهی** یا در **صفحه جزئیات** آن باز کنید و از **تأیید برنامه** استفاده کنید (بخش ۶).

۸. فهرست رخدادها و جزئیات رخداد

۸٫۱ رخدادها

منو: رخدادها. همهٔ رخدادهای فعال در یک جدول.

80:32:11

۳۱ شهریور ۱۴۰۳

FA

EN

پاسخ خودکار

مدل زبانی

کارگزار هوش مصنوعی

اسپلنک

سلامت سامانه

ریسک موجودیت‌ها

پارگانی

رخدادها

هشدارهای زنده

مرکز فرماندهی

AO-SOC

مرکز فرماندهی

صف رخدادها

همه رخدادهای همیشه در محیط

شدت	وضعیت	عنوان	ریسک	اطمینان	باز کردن
بازرسی زنده	فعال	ALT-BE524263A0B8ET RANSOMWARE Ryuk style file extension	97	94%	←
بازرسی زنده	فعال	ALT-93C4062FE914ET EXPLOIT Possible EternalBlue SMB attempt	97	94%	←
بازرسی نمایشی	فعال	INC-2041Possible Ransomware Activity on FIN-WIN-04	97	94%	←
بالا زنده	فعال	ALT-A67AAB651D86ET INFO Suspicious TLS SNI to DGA-like domain	78	88%	←
بالا زنده	فعال	ALT-C1D352574123ET DNS Query for .onion TLD	78	88%	←
بالا زنده	فعال	ALT-B631244AFD55ET POLICY Suspicious inbound to MSSQL port 1433	78	88%	←
بالا زنده	فعال	ALT-FC7173C73670ET POLICY Powershell DownloadString	78	88%	←
بالا زنده	فعال	ALT-1AC3F5974890ET MALWARE Known C2 Beacon	78	88%	←
بالا نمایشی	در حال بررسی	INC-2040Brute Force Campaign against VPN Gateway	78	88%	←
متوسط زنده	فعال	ALT-3920D957346CET WEB_SERVER SQL Injection Attempt	62	71%	←
متوسط زنده	فعال	ALT-BC126E54C699ET SCAN Potential SSH Scan	62	71%	←
متوسط نمایشی	باز	INC-2039Suspicious Cloud IAM Role Assumption	62	71%	←
پایین نمایشی	تحت نظارت	INC-2038Outdated TLS Handshake on External Endpoint	31	64%	←

اسپلنک - کارگزار هوش مصنوعی - مدل زبانی (Qwen) - پاسخ خودکار

مرکز فرماندهی AO-SOC - v2.8.8

ستون‌ها: شدت، وضعیت (با نشان زنده یا نمایشی)، عنوان، ریسک، اطمینان هوش مصنوعی و باز کردن. روی یک سطر کلیک کنید تا صفحهٔ جزئیات آن باز شود.

08:32:14 ۳۱ شهریور ۱۴۰۲ FA EN پاسخ خودکار مدل زبانی کارگزار هوش مصنوعی اسپلنک سلامت سامانه آپ ریسک موجودیتها پایگانی رخدادها هشدارهای زنده مرکز فرماندهی AO-SOC مرکز فرماندهی

ALT-BE524263A0D8 → بازگشت به مرکز فرماندهی

ET RANSOMWARE Ryuk style file extension فعال بحرانی

21:01 → 21:01 - مرحله 2

سناریوی حمله

T1486 **IDS Alert** 08:48 ①
ET RANSOMWARE Ryuk style file extension triggered

T1486 **Follow-on** 08:48 ②
Sustained session 10.4.17.20 → 10.4.22.8

وضعیت امنیتی
1 تشخیص، سیستم‌شده از 1 ابزار
SPLUNK

اعتبار ریسک همبستگی
45+ بیشترین شدت میان 1 تشخیص برابر MEDIUM است
همیشه بر اساس
10.4.22.8 ② 10.4.17.20 ②
تشخیص‌های عضو
04:10 **متوسط** **SPLUNK** >
ET RANSOMWARE Ryuk style file extension

راستی‌آزمایی و سابقه
چه چیزی در برابر یک مرجع بررسی شد و این مرکز عملیات پیشتر چه تصمیمی گرفته است
هیچ نشانه‌ای از این وضعیت در فید local یافت نشد.
2 مورد بررسی شد (نشانه‌های داخلی و هویت‌ها مرکز به فید فرستاده نمی‌شوند)
سابقه
سابقه به‌اندازه مشاوره وجود ندارد - این تصمیم به‌اختیار طراحی منتظر تحلیل‌گر می‌ماند.

پرونده
چه کسی روی آن کار می‌کند و در چه وضعیتی است
PI تازه CASE-9934DEBB3A

تصمیم سطح ۲ هوش مصنوعی
یکبار بررسی کنید - SOAR کلی برنامه را خودکار اجرا می‌کند
احتمالاً: 95% **در انتظار تأیید** **ESCALATE** ①

استدلال
Mass file rename pattern consistent with Ryuk ransomware staging on .shared drive. Tier-2 verdict ESCALATE for 10.4.17.20 → 10.4.22.8

ریسک در صورت اجرا
Pulls the IR team in out of hours and pauses Tier-2 handling

برنامه اقدام یکپارچه (3)

Block IP ① **توضیح بیشتر**
هدف: 10.4.22.8
Malicious or suspicious peer
Unblock IP **بازگردانی** بازگردانی به Unblock IP
بازگردانی پس از اجرای اقدام در دسترس می‌شود

Isolate Host ① **توضیح بیشتر**
هدف: 10.4.17.20
Active malicious activity
Release host from isolation به بازگردانی به بازگردانی پس از اجرای اقدام در دسترس می‌شود

Investigate ① **توضیح بیشتر**
هدف: 10.4.17.20
Memory triage for credential theft

تأیید برنامه **ویرایش** **رد**

رد پای حساسیت

برای هر رخداد یک صفحه، با همه‌چیز در یک‌جا:

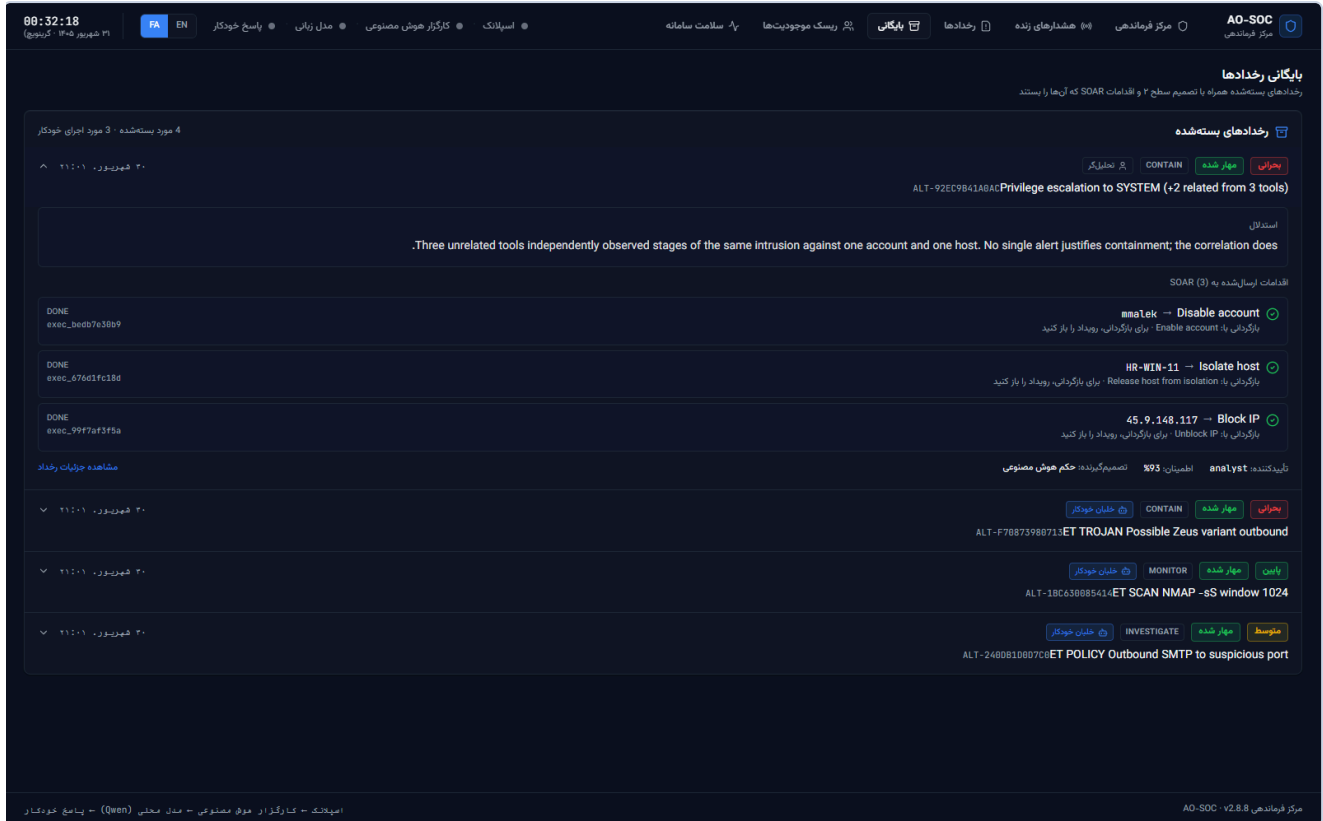
- پیوند بازگشت به مرکز فرماندهی، شناسه، شدت، وضعیت و عنوان رخداد.
- ستون راست: سناریوی حمله، وضعیت امنیتی، راستی‌آزمایی و سابقه، پرونده و توضیح هوش مصنوعی.
- ستون چپ: تصمیم سطح ۲ هوش مصنوعی (با همه دکمه‌ها)، دارایی‌های متأثر، تکنیک‌های MITRE و اقدامات پیشنهادی هوش مصنوعی.

از این صفحه وقتی استفاده کنید که می‌خواهید پیوند یک رخداد را به اشتراک بگذارید، یا اقدامی را روی رخدادی که مهار شده بازگردانی کنید (بخش ۹٫۲).

۹. بایگانی و بازگردانی اقدامها

۹/۱ بایگانی

منو: بایگانی. رخدادهای بسته‌شده، جدیدترین در بالا.



- سرآیند، شمار رخدادهای **بسته‌شده** و شمار موارد **اجرای خودکار** را نشان می‌دهد.
- هر سطر: شدت، **مهار شده**، حکم، و **تحلیل‌گر** یا **خلبان خودکار** یعنی تأییدکننده.
- **روی یک سطر کلیک کنید** تا **استدلال**، همه اقدامات ارسال‌شده به **SOAR** با وضعیت و شناسه اجرا، تأییدکننده، اطمینان و منبع تصمیم را ببینید.
- **مشاهده جزئیات رخداد** صفحه کامل رخداد را باز می‌کند.

۹/۲ بازگردانی یک اقدام

هر اقدامی که **قابل بازگردانی** باشد، پس از اجرا قابل پس‌گرفتن است. برای نمونه، *Block IP* با *Unblock IP* بازگردانده می‌شود.

۱. در بایگانی روی **مشاهده جزئیات رخداد** کلیک کنید. اگر رخداد هنوز فعال است، از مرکز فرماندهی هم می‌توانید.

۲. در پنل تصمیم سطح ۲ هوش مصنوعی، اقدام را پیدا کنید و روی **بازگردانی** کلیک کنید.

تصمیم سطح ۲ هوش مصنوعی یکبار بررسی کنید - SOAR کل برنامه را خودکار اجرا می‌کند

اطمینان: 93%

تکمیل

CONTAIN

استدلال

Three unrelated tools independently observed stages of the same intrusion against one account and one host. No single alert justifies containment; the correlation does.

ریسک در صورت اجرا

Disabling mmalek locks an HR user out mid-shift and isolating HR-WIN-11 drops any in-flight payroll session on that endpoint.

برنامه اقدام یکپارچه (3)

DONE

Disable account

نوشتن پرخطر

هدف: mmalek

Confirmed credential compromise

از طریق soar

exec_bedb7e38b9

بازگردانی یا: Enable account

قابل بازگردانی

بازگردانی

DONE

Isolate host

نوشتن پرخطر

هدف: HR-WIN-11

SYSTEM-level compromise

از طریق soar

exec_676d1fc18d

بازگردانی یا: Release host from isolation

قابل بازگردانی

بازگردانی

DONE

Block IP

نوشتن پرخطر

هدف: 45.9.148.117

Low-reputation egress peer

از طریق soar

exec_99f7af3f5a

بازگردانی یا: Unblock IP

قابل بازگردانی

بازگردانی

اجرای SOAR تکمیل شد - رخداد مهار شد

در عمل چه شد

تا 72 ساعت پس از قطعی شدن تصمیم قابل ثبت است.

بازگشایی شده

مثبت کاذب

مثبت درست

رد پای حسابرسی

۳. در صورت تمایل دلیل را بنویسید؛ مثلاً «پنجره تغییر CHG-2211 این ترافیک را تأیید کرده بود».

۴. برای تأیید، دوباره روی بازگردانی کلیک کنید.

تصمیم سطح ۲ هوش مصنوعی یکبار بررسی کنید - SOAR کل برنامه را خودکار اجرا می‌کند

اطمینان: 93%

تکمیل

CONTAIN

استدلال

Three unrelated tools independently observed stages of the same intrusion against one account and one host. No single alert justifies containment; the correlation does

ریسک در صورت اجرا

Disabling mmalek locks an HR user out mid-shift and isolating HR-WIN-11 drops any in-flight payroll session on that endpoint

برنامه اقدام یکپارچه (3)

DONE

نوشتن پرخطر

Disable account

هدف: mmalek

Confirmed credential compromise

از طریق soar

exec_bedb7e30b9

پارگردانی یا: Enable account

قابل بازگردانی

این اقدام پس گرفته شود؟

مثلاً: پنجره تغییر CHG-2211 این ترافیک را تأیید کرده بود

بازگردانی

انصراف

DONE

نوشتن پرخطر

Isolate host

هدف: HR-WIN-11

SYSTEM-level compromise

از طریق soar

exec_676d1fc18d

پارگردانی یا: Release host from isolation

قابل بازگردانی

بازگردانی

DONE

نوشتن پرخطر

Block IP

هدف: 45.9.148.117

Low-reputation egress peer

از طریق soar

exec_99f7af3f5a

پارگردانی یا: Unblock IP

قابل بازگردانی

بازگردانی

اجرای SOAR تکمیل شد - رخداد مهار شد

در عمل چه شد

تا 72 ساعت پس از قطعی شدن تصمیم قابل ثبت است.

بازگشایی شده

مثبت کاذب

مثبت درست

ردپای حسابرسی

اقدام بازگرداننده از همان مسیر اقدام اصلی فرستاده می‌شود. سپس اقدام وضعیت «توسط نام شما بازگردانده شد» می‌گیرد و رخداد به‌جای اینکه «مهار شده» بماند **بازگشایی** می‌شود. سوابق پرونده ثبت می‌کند چه کسی چه چیزی را بازگرداند.

- دکمه **بازگردانی** فقط پس از اجرای اقدام نمایش داده می‌شود.
- اقدام **بازگشت‌ناپذیر** دکمه بازگردانی ندارد.

- پیام «مجری بازگردانی را نپذیرفت» یعنی ابزار پاسخ فرمان بازگرداننده‌ای ندارد. اقدام را مستقیماً در همان ابزار برگردانید.

۱۰. ریسک موجودیت‌ها

منو: ریسک موجودیت‌ها. موجودیت‌های با بالاترین امتیاز ریسک در کل محیط.

۰۸:۳۲:۲۶
۳۱ شهریور ۱۴۰۵ - گریبوج

FA

EN

بالا (97)

وضعیت امنیتی

پاسخ خودکار

مدل زمانی

کارگزار هوش مصنوعی

اسپلنک

سلامت سامانه

ریسک موجودیت‌ها

پیگیری رخدادها

هشدارهای زنده

مرکز فرماندهی

AO-SOC

ریسک موجودیت‌ها

موجودیت‌های با بالاترین امتیاز ریسک

ریسک کاربران

5 از 5 نمایش داده شده

نام	ریسک	اطمینان‌دلیل	آخرین مشاهده
jdoe@corp	97	Token impersonation + LSASS dump 94%	08:17
asmith@corp	88	MFA fatigue accepted 86%	08:12
klee@corp	71	After-hours admin activity 78%	02:41
svc_bak@corp	64	Unusual data volume access 68%	04:08
rmohan@corp	58	Geo anomaly from new device 62%	07:55

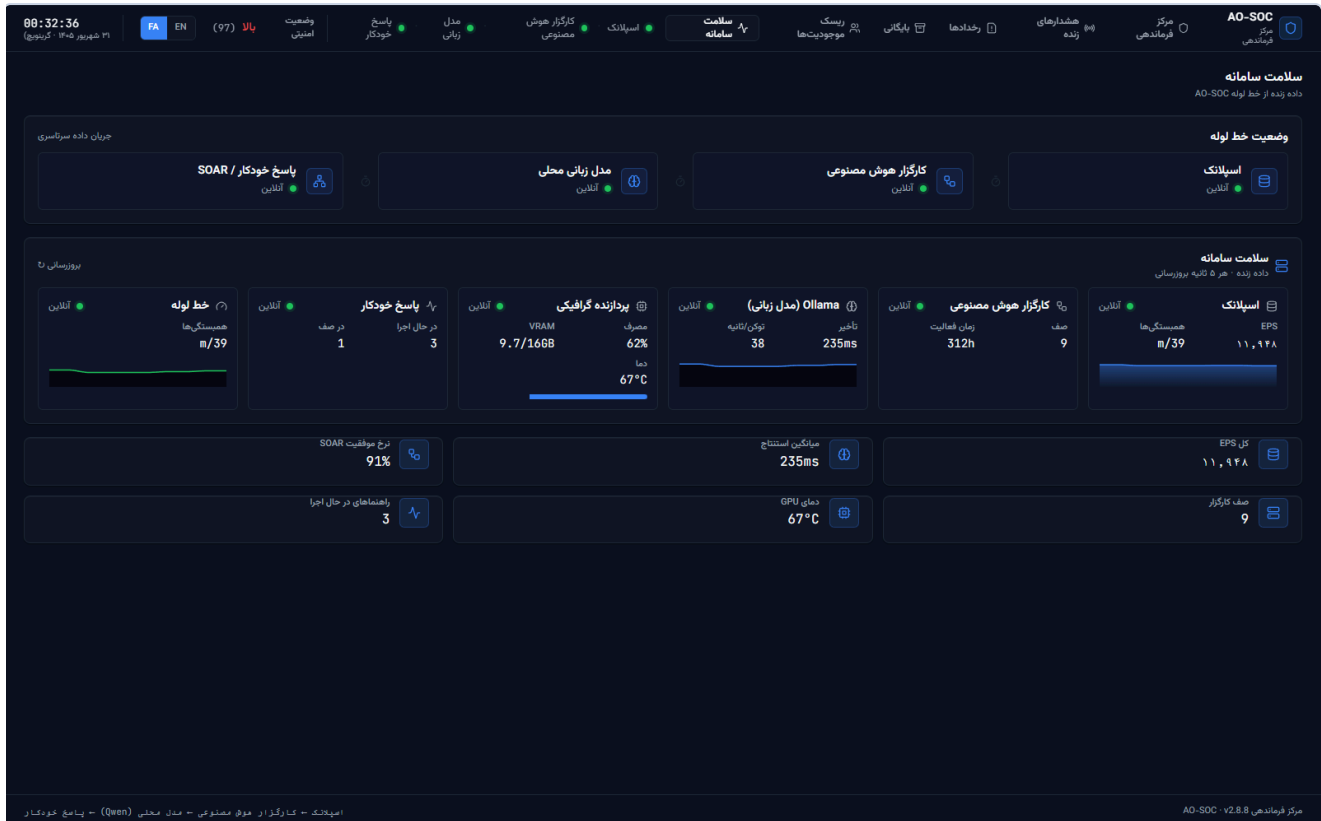
مرکز فرماندهی AO-SOC - v2.8.8

اسپلنک - کارگزار هوش مصنوعی - مدل معنایی (Qwen) - پاسخ خودکار

- با زبانه‌های **کاربران**، **میزبان‌ها** و **IP‌ها** میان فهرست‌ها جابه‌جا شوید.
 - کادر **جستجو...** فهرست را هم‌زمان با تایپ پالایش می‌کند.
 - هر سطر: نام، امتیاز **ریسک** (با نوار رنگی)، **اطمینان** مدل، **دلیل** و **آخرین مشاهده**.
- از این صفحه برای پاسخ به این پرسش استفاده کنید: «اکنون چه کسی یا چه چیزی بیشترین ریسک را دارد؟» و نیز برای اینکه ببینید حساب یا میزبان یک رخداد سابقه‌ای دارد یا نه.

۱۱. سلامت سامانه

منو: سلامت سامانه. آیا خط لوله زنده است؟

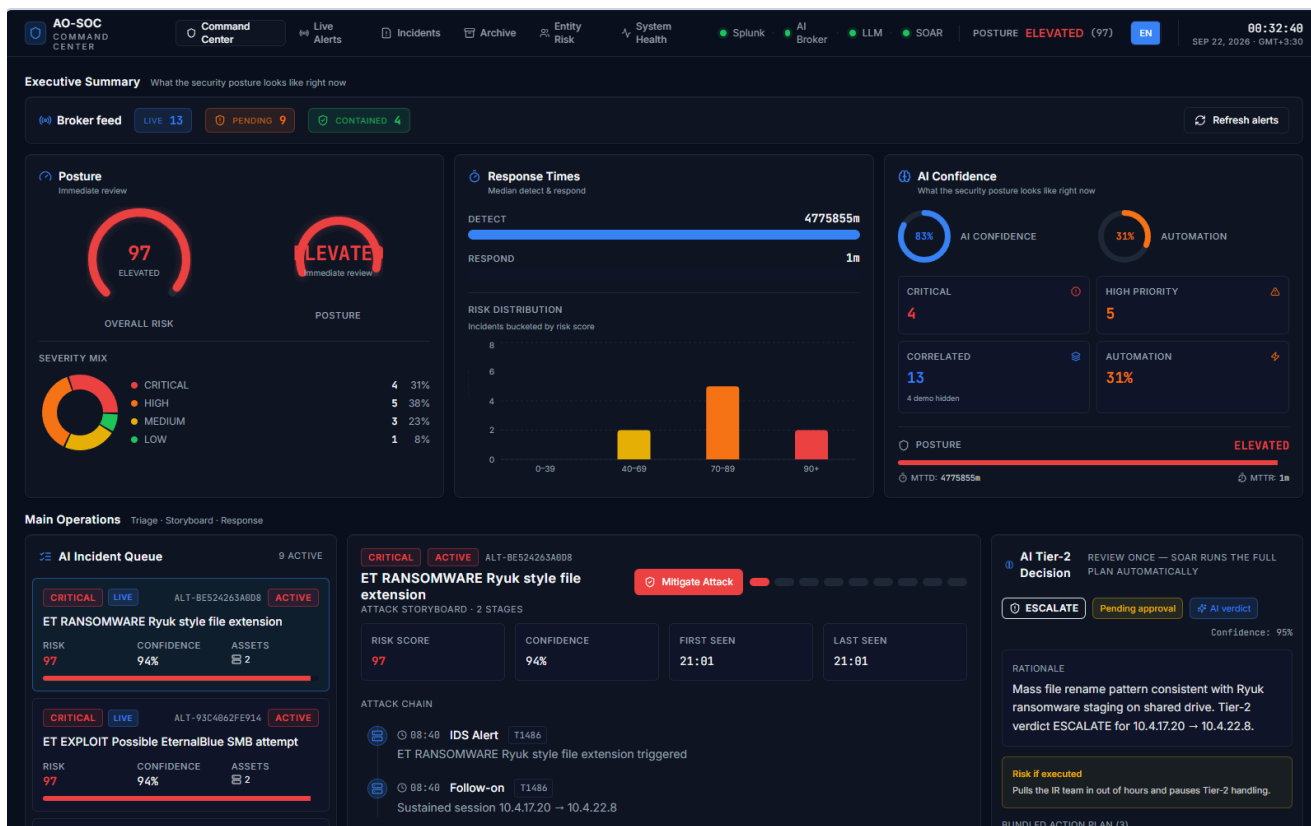


- وضعیت خط لوله: اسپلنک ← کارگزار هوش مصنوعی ← مدل زبانی محلی ← پاسخ خودکار / SOAR، هر کدام آنلاین، تضعیف شده، آفلاین یا نامشخص.
- داده زنده (هر ۵ ثانیه): رویداد در ثانیه و همبستگی‌ها (اسپلنک)، طول صف و زمان فعالیت (کارگزار)، تأخیر و توکن در ثانیه (مدل)، مصرف، VRAM و دمای پردازنده گرافیکی، و اقدام‌های در حال اجرا و در صف (SOAR).
- کاشی‌های خلاصه: کل EPS، میانگین استنتاج، نرخ موفقیت SOAR، صف کارگزار، دمای GPU و راهنماهای در حال اجرا.

اگر جزئی قرمز یا خاکستری است، بخش ۱۵ را ببینید.

۱۲. زبان: فارسی و انگلیسی

روی **EN** در نوار بالا کلیک کنید تا رابط انگلیسی شود و روی **FA** برای بازگشت به فارسی. رابط فارسی راست‌به‌چپ است و برچسب‌ها، تاریخ‌ها (خورشیدی) و توضیح عوامل ریسک هم فارسی می‌شوند. انتخاب شما در همین مرورگر به خاطر سپرده می‌شود.



آغاز شیفت

۱. با **کلید خودتان** وارد شوید.
 ۲. به نوار بالا نگاه کنید: آیا هر چهار نقطه خط لوله **سبز** است؟ اگر نه، **سلامت سامانه** را باز کنید.
 ۳. خلاصه **مدیریتی** را بخوانید: وضعیت امنیتی، شمار رخدادهای **در انتظار** و ترکیب شدت.
- در طول شیفت، برای هر رخداد صف رخدادهای هوش مصنوعی (از بالا)**
۱. **انتخابش کنید.**
 ۲. **بخوانید:** سناریوی حمله، سپس **وضعیت امنیتی** (چه چیزی آن را به هم پیوند داده)، سپس **راستی‌آزمایی و سابقه.**

۳. **مسئولیت را بپذیرید:** در پرونده آن را به خودتان واگذار کنید و وضعیت را «در دست بررسی» بگذارید.
۴. **تصمیم بگیرید،** در پنل تصمیم سطح ۲ هوش مصنوعی:

- برنامه درست است ← **تأیید برنامه،**
- برنامه تا حدی اشتباه است ← **ویرایش و سپس تأیید،**
- نباید چیزی اجرا شود ← **رد،** با یادداشت،
- به سطح بالاتر نیاز دارد ← **ارجاع به سطح بالاتر** در پنل پرونده.

۵. نکته‌های مفید را در سوابق پرونده **یادداشت کنید.**
۶. پس از بسته‌شدن، مدخل آن را در **بایگانی** بررسی کنید.

پایان شیفت

۱. برای تصمیم‌هایی که امروز قطعی شدند، **مثبت درست / مثبت کاذب / بازگشایی‌شده** را ثبت کنید.
 ۲. پرونده‌هایی را که هنوز «در دست بررسی» هستند تحویل دهید: یادداشت بگذارید و دوباره واگذار کنید.
 ۳. زبانه مرورگر را ببندید تا از سامانه خارج شوید.
- برای سرپرست شیفت (هفتگی):** یک پشتیبان بگیرید و درستی آن را بسنجید (بخش ۷ برنامه راه‌اندازی) و بررسی کنید کدام منابع تشخیص مثبت کاذب تولید می‌کنند.

۱۴. واژه‌نامه: نشان‌ها، رنگ‌ها و وضعیت‌ها

رنگ شدت: بحرانی قرمز * بالا نارنجی * متوسط زرد * پایین سبز.
وضعیت امنیتی: پایین ← محافظت‌شده ← افزایش‌یافته ← بالا (بدترین).

اصطلاح	معنا
زنده / نمایشی	داده واقعی کارگزار / داده نمونه داخلی
وضعیت امنیتی (Situation)	یک یا چند تشخیص، احتمالاً از چند ابزار، درباره موجودیت‌های یکسان در یک بازه زمانی
تصمیم سطح ۲	حکم: CONTAIN (اکنون مهار کن)، ESCALATE (سطح بالاتر یا تیم پاسخ به حادثه را درگیر کن)، INVESTIGATE (عمیق‌تر بررسی کن)، MONITOR (زیر نظر بگیر)، IGNORE (اقدامی لازم نیست)
برنامه اقدام یکپارچه	راهنما: مجموعه اقدام‌های پیوسته به یک تصمیم که با هم تأیید و اجرا می‌شوند
حکم هوش مصنوعی / بازگشت به قاعده / اصلاح تحلیل‌گر	اینکه تصمیم را مدل، قاعده شدت یا یک انسان داده است
فقط خواندن / نوشتن کم‌خطر / نوشتن پرخطر / مخرب	میزان تغییری که یک اقدام ایجاد می‌کند. اقدام مخرب رد می‌شود مگر اینکه سازمان آگاهانه آن را فعال کرده باشد
قابل بازگردانی / بازگشت‌ناپذیر / چیزی برای بازگرداندن نیست	اینکه اقدام را می‌توان پس گرفت یا نه
دارایی حیاتی / حساب دارای دسترسی ویژه / حساب سرویس	هدف‌هایی که خلبان خودکار هرگز به آنها دست نمی‌زند
در انتظار تأیید ← تأیید شده ← در حال اجرا ← تکمیل	ترتیب عادی وضعیت یک برنامه
ناموفق	ابزار پاسخ درخواست را دریافت و رد کرد؛ دلیل در رسید آمده است
مسدود (BLOCKED)	اقدام اصلاً از AO-SOC خارج نشد؛ هدف نادرست بود یا هیچ ابزاری آن را انجام نمی‌دهد
اجرای آزمایشی	فقط شبیه‌سازی؛ چیزی به هیچ ابزاری فرستاده نشد
جایگزین شده	وضعیت در وضعیت دیگری ادغام شده و تصمیم جاری آنجاست
سابقه	موارد مشابه پیشین که انسان‌ها درباره‌شان تصمیم گرفته‌اند و خلبان خودکار به آنها تکیه می‌کند
وضعیت‌های پرونده	تازه، واگذارشده، در دست بررسی، ارجاع‌شده، حل‌شده، بسته‌شده، بازگشایی‌شده
MTTD / MTTR	میانگین زمان شناسایی / میانگین زمان پاسخ

۱۵. رفع اشکال

نشانه	اقدام
صفحه ورود مدام برمی‌گردد	کلید نادرست یا باطل است، یا کلید کارگزار است نه کلید داشبورد. از مدیر سامانه کلیدی از <code>AOSOC_API_KEYS</code> بخواهید
پیام «بارگذاری داشبورد ناموفق بود ... پورت 4317»	API رابط کاربری اجرا نمی‌شود. حالت نمایشی: <code>start-demo</code> را دوباره اجرا کنید. Docker: <code>docker compose -f deploy/docker-compose.yml ps</code>
صف خالی است	بررسی کنید ابزارهای تشخیص با کلید ingest به کارگزار می‌فرستند. حالت نمایشی: <code>start-demo</code> را دوباره اجرا کنید یا در ویندوز <code>orchestrator\trigger-alert.ps1</code> را
رخدادهای تازه تصمیم نمی‌گیرند	شاید صف تحلیل کارهای ناموفق دارد. از مدیر سامانه بخواهید <code>GET /api/queue</code> را روی کارگزار بررسی کند. تشخیص‌ها در هر حال ذخیره شده‌اند و قابل تکرارند
همه تصمیم‌ها بازگشت به قاعده هستند	مدل پاسخ نمی‌دهد. نقطه مدل زبانی و صفحه سلامت سامانه را ببینید؛ مطمئن شوید Ollama اجراست و مدل دریافت شده است
اقدامی ناموفق است	ابزار پاسخ آن را نپذیرفت؛ دلیل در رسید تحویل آمده است. مشکل را در همان ابزار رفع کنید یا برنامه را ویرایش کنید
اقدامی مسدود است	هدف برای آن اقدام معتبر نیست یا هیچ رابطی آن را اجرا نمی‌کند. برنامه را ویرایش و هدف را اصلاح کنید
همه چیز اجرای آزمایشی است	استقرار هنوز در حالت آزمایشی است (<code>RESPONSE_DRY_RUN=true</code>). تا مرحله ۲ برنامه راه‌اندازی، این طراحی عمدی است
وضعیت پرونده تغییر نمی‌کند	آن جابه‌جایی مجاز نیست. فقط دکمه‌های نمایش‌داده‌شده وضعیت‌های مجاز بعدی‌اند
نقطه‌های خط لوله خاکستری (نامشخص) هستند	بررسی سلامت هنوز پاسخ نداده است. ۵ ثانیه صبر کنید یا صفحه را از نو بارگذاری کنید. اگر خاکستری ماند، اجرای کارگزار را بررسی کنید

هنگام گزارش اشکال، **نسخه** را از پانویس، **شناسه رخداد** (مثلاً `ALT-8AE6D52F8208`) و در صورت امکان فایل دریافت **JSON** از ردپای حسابرسی را همراه کنید.

تاریخچه تغییرات

نویسنده	تغییر	تاریخ	نسخه
J.Ekrami, Claude (Opus 5)	ویرایش نخست برای ao-soc نسخه ۲/۸/۹: نصب (نمایشی و Docker)، ورود، همهٔ منوها و صفحه‌ها، روند تصمیم سطح ۲ (تأیید، ویرایش، رد، حسابرسی، نتیجه، بازگردانی)، راهنمای رخداد در هشدارهای زنده، روال روزانه، واژه‌نامه و رفع اشکال. ۳۰ تصویر از رابط فارسی محیط نمایشی	تابستان ۱۴۰۵	۱/۰
J.Ekrami, Claude (Opus 5)	اصلاح تصویر پنل «وضعیت امنیتی» در بخش ۵/۲: تصویر ویرایش ۱/۰ به‌اشتباه کارت وضعیت امنیتی کلی را نشان می‌داد، چون هر دو یک عنوان دارند؛ تصویر درست در images_fa_v1.1/ است و بقیهٔ تصاویرها بدون تغییر از images_fa_v1.0/ می‌آیند. نسخه‌های PDF و Word این راهنما از همین فایل ساخته می‌شوند	تابستان ۱۴۰۵	۱/۱